

Zellic Sample Audit Report
Project: Sample DEX

Executive Summary

This is a synthetic Zellic style report used for testing.

Findings

Finding 1: Reentrancy in withdraw allows fund theft

Severity: High

Impact: High

Likelihood: Medium

Description

The withdraw function in contracts/Vault.sol:42 calls an external token before updating internal accounting state. An attacker can re-enter withdraw and drain the vault.

Recommendation

Apply the checks-effects-interactions pattern: update internal balances before the external token call. Add a non-reentrancy modifier to the withdraw function.

Finding 2: Integer overflow in fee calculation results in loss

Severity: Medium

Impact: Medium

Likelihood: Low

Description

The fee calculation in contracts/Fee.sol:100 multiplies two unchecked uint256 values which can overflow for large inputs.

Recommendation

Use Solidity 0.8+ checked arithmetic or SafeMath for the fee calculation. Add unit tests covering the boundary cases.